

Halden Distribution Ltd. — Backup and Recovery Policy

Field	Value
Policy ID	POL-BKP-001
Version	0.9 (draft for approval)
Owner	IT Lead
Approver	Managing Director — signature pending
Effective date	<i>(on approval)</i>
Review cycle	Annual, or after any drill, incident or significant change
Related policies	P10 policy pack (access control, change management, acceptable use)

Status: this policy is unsigned. The approval block at the end stays blank until a real review happens. It is a draft for the fictional company Halden Distribution Ltd. and is part of a home-lab portfolio project.

1. Purpose

To ensure Halden can recover its information and systems after accidental deletion, hardware failure, corruption or a deliberate attack, and to make the promise of recovery **testable** rather than assumed. This policy defines what is protected, how, for how long, who is responsible, and how it is verified.

2. Scope

All production systems, data and configurations in scope for backup:

Tier	Systems	Examples of data
0 — Foundation	DC01, DC02, FW01 configuration	Active Directory, DNS, DHCP, firewall config
1 — Critical	FS01, LNX01	Finance and Sales shares, order database
2 — Important	OPS01, SIEM01	GLPI tickets, BookStack pages, Wazuh logs
3 — Deferrable	Workstations	none locally by policy (data is redirected)

3. Principles

- 1. **Recovery is the product.** A backup job that succeeded is not evidence; a successful ****restore test**** is.
- 1. **The backup must not share the domain's fate.** The backup server is **not domain-joined** and uses credentials separate from day-to-day administration.
- 1. **At least one copy is immutable or offline.** A copy that an attacker with backup credentials can

delete is not a last line of defence.

1. **The business sets the objectives.** Recovery targets are agreed with the business (see the service-level table), not chosen by IT alone.

1. **Everything is measured.** Restore tests, drill times and immutability are proven with evidence.

4. The 3-2-1-1-0 rule

Rule	Requirement
3 copies	Live data, an on-site backup copy, and an off-site copy
2 media	At least two different storage types (disk repository and object storage/USB)
1 off-site	At least one copy held outside the main premises
1 immutable or offline	At least one copy that cannot be deleted or altered within its retention period
0 errors on verified restore	Restores are tested automatically and reported; a failure is an incident

5. Backup schedule and retention

As defined in `../configs/p08-backup-jobs.yaml` and `../configs/p08-retention-policy.md`. In summary:

Tier	Backup frequency	Retention	Immutable floor
0	Daily (VM + system state)	30 daily, 12 monthly	30 days
1	Hourly file + nightly VM	24 hourly, 14 daily, 8 weekly, 12 monthly	30 days
2	Nightly	14 daily, 8 weekly	30 days
3	None (re-imaged)	—	—

****The immutable retention period must never be shorter than the recovery window promised to the business.****

6. Encryption and key management

- Backup data is **encrypted**; the encryption key never leaves Halden's control.
- Keys and passphrases are stored in the **password manager** as the source of truth and are **never** committed to source control, written into scripts, or published.
- A **sealed offline copy** of the key is stored with the offline media so that a disaster does not destroy the only means of reading the backups.
- **Losing the key means losing the backups.** Key rotation is a planned, change-managed activity (re-initialise the repository and run a new full backup), never an ad-hoc action.

7. Access control

Role	Who	Permitted
Backup administrator	IT Lead / Systems	Configure jobs, restore, manage retention
Backup operator	Service Desk (on call)	Start a restore, verify a result
Backup writer (object store)	automated job only	Write and list; cannot delete protected versions
Everyone else	all other staff	No access to the backup service at all

Backup credentials are **separate from domain credentials**, and the backup server is reachable only from the management network on the backup ports.

8. Verification (the "0")

- A **weekly automated restore test** restores a sample of files, checks their integrity against the hashes recorded at backup time, restores a virtual machine into an isolated sandbox and runs service health checks.
- The result is **published to monitoring**; a failure raises a **high-priority alert** and a service ticket, and is not downgraded to a warning.
- A **full recovery drill** is run at least **twice a year** and after any significant change to the environment. The drill results, including anything that failed, are reported to management.

9. Roles and responsibilities

Role	Responsibility
Managing Director	Approves the policy and the recovery objectives; declares a disaster with IT
IT Lead	Owens this policy, runs drills, reports results, maintains the runbook
Systems	Operates backups, investigates failures, performs restores
Department heads	Confirm their systems work after a recovery; own the impact tolerance for their area
All staff	Store work in the managed location; report suspected data loss promptly

10. Non-compliance and exceptions

- Any bypass of the immutability or retention settings requires the IT Lead's written approval and a recorded, time-limited exception.
- Retention decreases must be re-approved by the business, because they shorten the recovery window.
- A system that cannot be backed up (for licensing, size or technical reasons) must be recorded as an accepted risk with the approval of the Managing Director.

11. Review

Reviewed annually, or sooner if: a drill fails to meet a target, an incident exposes a gap, a system is added or removed, or a significant change is made to the backup configuration.

12. Related documents

- Service levels and recovery objectives: `p08-service-levels.md`
- Disaster recovery plan: `p08-dr-plan.md`
- Restore-test register: `p08-restore-test-register.md`
- Change record: `p08-change-record.md`
- Runbooks: `../docs/runbooks/`

Approval

Role	Name	Signature	Date
Policy owner (IT Lead)	Muhammad Ibrahim Akmal		
Approver (Managing Director)			

Unsigned draft. Halden Distribution Ltd. is a fictional company; this approval block represents the lab owner's decision process, not a real customer signature.